Pickle Rick: Write Up

Plataforma: TryHackMe

Máquina / Desafio:	Pickle Rick
Dificuldade:	Fácil
Data de Resolução:	27 de agosto de 2026
Autor:	Alan Dias (alankk)

27 de agosto de 2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **4**

4 Escalada de Privilégios **5**

5 Conclusão **6**

6 Referências **6**

1 Visão Geral

A máquina Pickle Rick é um desafio temático focado na exploração de serviços web básicos e sistemas operacionais Linux. A superfície de ataque se concentra na numeração detalhada de uma aplicação web para a obtenção de credenciais válidas. O caminho geral para o comprometimento total inicia-se na inspeção de páginas expostas, evolui para a injeção de comandos (ou execução remota) em painéis logados, e culmina na escalada de privilégios via comandos `sudo` mal configurados, a fim de coletar três ingredientes secretos espalhados pelo sistema.

2 Reconhecimento

A fase de reconhecimento começou com uma varredura de portas utilizando o `nmap`. O objetivo foi identificar os serviços ativos e suas respectivas versões.

```
nmap -A -T4 <TARGET_IP>
```

Resultado do Nmap (trecho relevante):

```
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux;
   protocol 2.0)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
```

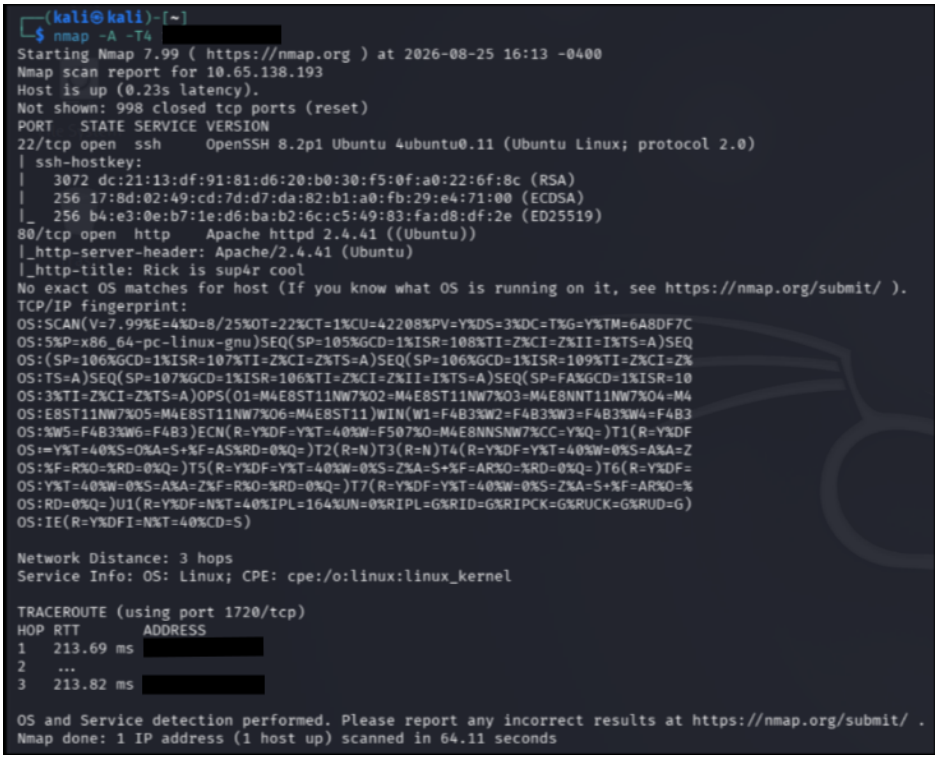


Figura 1: Varredura de portas com Nmap.

A varredura revelou duas portas abertas: 22 (SSH) e 80 (HTTP). Como a porta 80 estava rodando um Apache, o primeiro passo foi acessar a aplicação web pelo navegador. A página inicial (`index.html`)

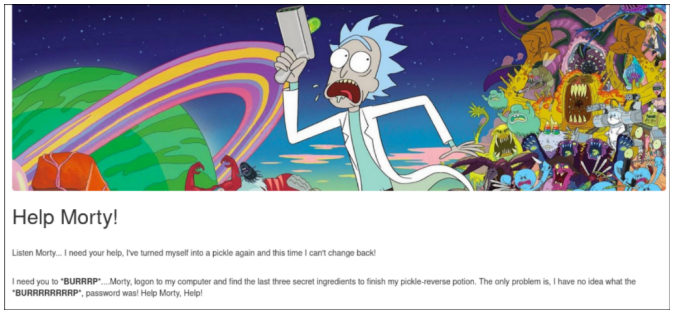


Figura 2: Página inicial do servidor web.

apresentava a temática da série *Rick and Morty*, e o personagem solicitava ajuda para encontrar três ingredientes secretos.

Inspecionando o código-fonte dessa mesma página inicial, foi encontrado um comentário HTML oculto contendo um provável nome de usuário.

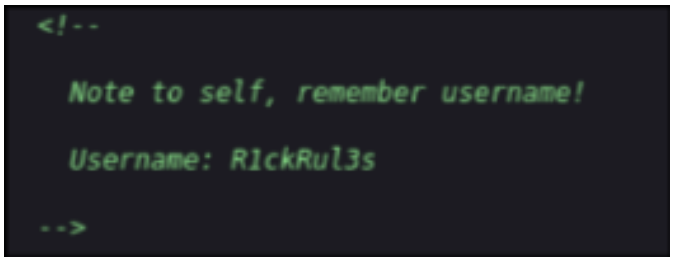


Figura 3: Comentário oculto no código-fonte revelando um nome de usuário: R1ckRul3s.

Para ampliar a superfície de ataque e descobrir novos vetores, executou-se uma enumeração de diretórios utilizando a ferramenta `feroxbuster`.

```
feroxbuster dir -u <TARGET_IP> -w /usr/share/wordlists/dirb/common.txt -x
   html,php,txt
```



Figura 4: Enumeração de diretórios utilizando feroxbuster.

A varredura localizou arquivos críticos, incluindo:

- `/assets/`
- `/login.php`
- `/portal.php` (que redirecionava o usuário não autenticado para login.php)
- `/robots.txt`

Investigando o arquivo `/robots.txt` no navegador, encontrou-se apenas uma string: `<PASSWORD>`, uma possível senha que seria útil mais adiante, na página `login.php`.

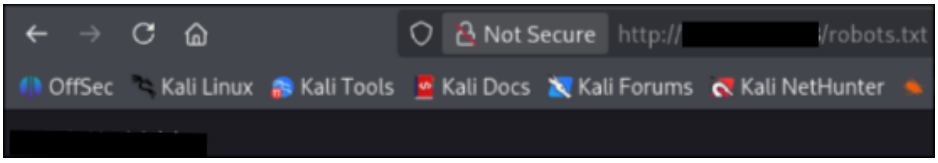


Figura 5: Conteúdo do arquivo robots.txt exibindo uma string incomum.

3 Exploração

Utilizando as credenciais descobertas durante a fase de reconhecimento (usuário `R1ckRul3s` e a senha `<PASSWORD>` do `robots.txt`), foi possível realizar a autenticação com sucesso na página `login.php`. O login concedeu acesso a um portal administrativo contendo um *Command Panel* (Painel de Comandos), cuja finalidade aparente era permitir a execução direta de comandos no sistema operacional base.



Figura 6: Painel de comandos descoberto após o login.

Esta vulnerabilidade de Injeção de Comandos (ou Execução Remota de Código) tornou-se o nosso vetor principal. Listando os arquivos no diretório atual, notou-se a presença de um arquivo suspeito chamado `Sup3rS3cretPickl3Ingred.txt`. Como alguns comandos diretos de leitura (como `cat`) costumam ser bloqueados nestes painéis, utilizou-se o utilitário `strings` para ler o conteúdo, revelando com sucesso o primeiro ingrediente.

```
strings Sup3rS3cretPickl3Ingred.txt
```

Explorando os diretórios acessíveis ao usuário atual do servidor web, verificou-se o diretório home do usuário rick (`/home/rick/`), que continha um arquivo chamado `second ingredients`. Lendo-o da mesma forma, o segundo ingrediente também foi recuperado.

```
strings /home/rick/second\ ingredients
```



Figura 7: Obtenção do primeiro ingrediente usando o comando strings.



Figura 8: Obtenção do segundo ingrediente no diretório /home/rick/.

4 Escalada de Privilégios

O próximo passo lógico foi a busca pelo terceiro e último ingrediente. Presumivelmente, ele estaria localizado em diretórios restritos (como o `/root/`), que exigem privilégios administrativos. Para verificar o escopo de privilégios do usuário atual (`www-data`), executou-se o comando `sudo -l` pelo próprio painel.



Figura 9: Saída do comando sudo -l revelando permissões totais.

O resultado revelou uma má configuração severa no sistema: o usuário `www-data` possuía permissão para executar qualquer comando como `root` sem a necessidade de fornecer uma senha (`NOPASSWD: ALL`).

Com essa permissão ativada, foi possível ler diretamente o conteúdo restrito no diretório do superusuário utilizando o comando `sudo` associado ao utilitário `strings`, a mesma técnica empregada anteriormente.

```
sudo strings /root/3rd.txt
```

O acesso a esse arquivo revelou o último ingrediente (`<FLAG>`), concluindo o desafio com sucesso.

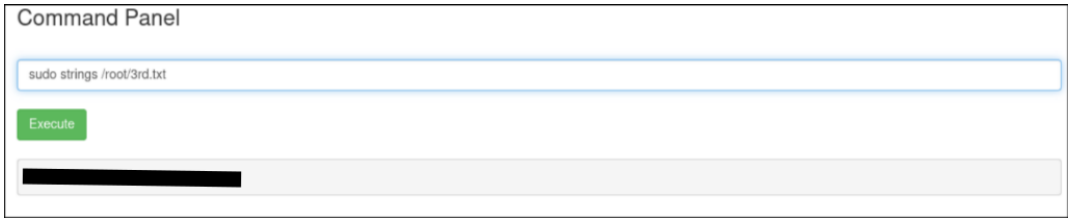


Figura 10: Captura do terceiro ingrediente lendo um arquivo protegido com sudo.

5 Conclusão

O desafio *Pickle Rick* demonstra na prática a importância de não expor informações confidenciais em comentários de código HTML ou em arquivos acessíveis como o `robots.txt`. A união dessas duas falhas simples de exposição de dados entregou as chaves de um painel vulnerável à execução arbitrária de comandos. Por fim, uma péssima prática de administração no `sudoers` permitiu que a conta de serviço padrão do servidor web assumisse o controle total da máquina de maneira instantânea.

6 Referências

- **feroxbuster - Kali Linux Tools:**
  https://www.kali.org/tools/feroxbuster/